

Part I. Can you find people trying to break into the servers?

Use Splunk's "Search" feature to try to answer the questions below.

Hint 1: On linux servers, secure.log contains security-related information. Typically in response to incidents, it is one of the first files people look at to see if there are compromises. Read this to see what to look for on Linux.

<https://zeltser.com/security-incident-log-review-checklist/>

Hint 2: To process the logs for analysis, first parse it using regular expressions to "extract fields" and turn unstructured data into structured data.

Answer the following questions and provide evidence with your answer.

Q1. How many hackers are trying to get access to our servers? And how many attempts are there? Explain/define how you count distinct hackers.

- 182 hackers.
- 33,253 events

The screenshot shows the Splunk New Pivot interface. At the top, it says "New Pivot" and "33,069 events (before 29/08/2022 16:56:17.000)". Below this, there are filters and split options. The filters section shows "All time" and three "username is ..." filters. The split rows section shows "ip_address". The split columns section shows "Distinct Value..." and "Count of 1661...". The main table displays the results of the search, with columns for "ip_address", "Distinct Values of username", and "Count of 1661766305.898". The table lists various usernames and their counts, such as "rdp from", "redmine from", "robbie from", "root from", "sapadmin from", "services from", "shoutcast from", "sleepy from", "squid from", "sys from", "sysadmin from", "system from", "testing from", "testuser from", "tomcat from", "ubuntu from", "vmware from", "vpxuser from", "whois from", "workshop from", and "yp from".

ip_address	Distinct Values of username	Count of 1661766305.898
	rdp from	
	redmine from	
	robbie from	
	root from	
	sapadmin from	
	services from	
	shoutcast from	
	sleepy from	
	squid from	
	sys from	
	sysadmin from	
	system from	
	testing from	
	testuser from	
	tomcat from	
	ubuntu from	
	vmware from	
	vpxuser from	
	whois from	
	workshop from	
	yp from	

- From extracting fields of username, and ip_address from log lines which are logging text with 'Failed password', I filtered only hackers sorting by the number of usernames they had sent to login, but not succeed. There are 3 real users (id = {183, 184, 185}) who were trying to login with wrong password inputted.

182	198.35.1.75	administrator from angel from backup from bashful from ben from bin from db from dbase from demo from demon from desktop from dwane from email from ftpuser from games from git from guest from gustavo from harrypotter from helpdesk from inet from
-----	-------------	---

183	10.3.10.46	djohnson from
184	10.1.10.172	myuan from
185	10.2.10.163	nsharpe from

Q2. What time do hackers appear to try to hack our servers?

- The hackers usually attempted to brute-force at 0:15 AM over those 7 days.

date_hour

1 Value, 100% of events

Selected

YesNo

Reports

Average over time

Top values

Events with this field

Maximum value over time

Top values by time

Minimum value over time

Rare values

Avg: 0 Min: 0 Max: 0 Std Dev: 0

Values	Count	%
0	33,253	100%

date_minute

1 Value, 100% of events

Selected

YesNo

Reports

Average over time

Top values

Events with this field

Maximum value over time

Top values by time

Minimum value over time

Rare values

Avg: 15 Min: 15 Max: 15 Std Dev: 0

Values	Count	%
15	33,253	100%

date_second



4 Values, 100% of events

Selected

Yes

No

Reports

[Average over time](#)

[Maximum value over time](#)

[Minimum value over time](#)

[Top values](#)

[Top values by time](#)

[Rare values](#)

[Events with this field](#)

Avg: 3.954259766036147 **Min:** 2 **Max:** 6 **Std Dev:** 1.5897640095823244

Values	Count	%	
2	8,798	26.458%	
3	8,267	24.861%	
6	8,154	24.521%	
5	8,034	24.16%	

Q3. Which server (mailsv, www1, www2, www3) sees the most attempts?

- The www1 server had the most attempts of brute-force by hackers.

source	count(RootObject)
tutorialdata.zip:./mailsv/secure.log	8154
tutorialdata.zip:./www1/secure.log	8798
tutorialdata.zip:./www2/secure.log	8034
tutorialdata.zip:./www3/secure.log	8267

Q4. What is the most popular account that hackers use to try to break in?

- 'root'

(The string "from" after username is added, because of my regex syntax to extract usernames from log files.)

username



>100 Values, 97.185% of events

Selected

Yes

No

Reports

Top values

Top values by time

Rare values

Events with this field

Top 10 Values	Count	%	
root from	1,493	4.62%	
administrator from	1,020	3.156%	
admin from	938	2.902%	
operator from	923	2.856%	
mail from	753	2.33%	
mailman from	752	2.327%	
irc from	644	1.993%	
email from	626	1.937%	
games from	601	1.86%	
sys from	586	1.813%	

Part II. Sensitive Files on Web Servers

Hint: On web servers, access.log contains web access-related information. Typically in response to incidents, it is one of the first files people look at to see if there are compromises. Read this to see what to look for on Web Servers.

<https://zeltser.com/security-incident-log-review-checklist/>

Q5. Can you find attempts to get access to sensitive information from our web servers?

How many attempts were there?

- I considered only log messages with specific status codes which are 400, 403, and 500 from recommended review checklist.

Then, I got the number of suspicious events (from hackers) was 1,662.

✓ 1,662 events (before 29/08/2022 20:14:22.000)

Filters: All time

Split Columns: +

Split Rows: RootObject.st..., RootObject.ur...

Column Values: Count of 1661...

RootObject.status_code	RootObject.url_path	Count of 1661778414.1101
400	/cart.do	182
400	/category.screen	152
400	/oldlink	166
400	/product.screen	201
403	/cart.do	56
403	/category.screen	59
403	/oldlink	58
403	/product.screen	55
500	/cart.do	190
500	/category.screen	163
500	/oldlink	191
500	/product.screen	189

Q6. What resource/file are hackers looking for?

- After the log messages were filtered with those status code, the files, attempted to reach by the hackers, were product.screen, cart.do, oldlink, and category.screen.

file



4 Values, 100% of events

Selected

Yes

No

Reports

Top values

Top values by time

Rare values

Events with this field

Values	Count	%	
product.screen	445	26.775%	
cart.do	428	25.752%	
oldlink	415	24.97%	
category.screen	374	22.503%	

Part III. Are there bots crawling our websites?

Q7. Can you find any bots crawling our websites?

- I found 4 bots by filtering User-Agent with words of 'bot', and 'bots.'

✓ 1,849 events (before 29/08/2022 21:14:30.000)		Documentation ⓘ	
Filters	Split Columns		
All time	+		
Split Rows	Column Values		
useragent	Count of 1661...		
useragent		Count of 1661782448.1304	
Googlebot/2.1 (http://www.googlebot.com/bot.html)		495	
Googlebot/2.1 (http://www.googlebot.com/bot.html)		439	
Mozilla/5.0 (compatible; Googlebot/2.1; +http://www.google.com/bot.html)		532	
Mozilla/5.0 (compatible; YandexBot/3.0; +http://yandex.com/bots)		383	

Q8. What are they doing on the site? (Hint: Look for User-Agent in the web access.logs.)

- They accessed to files and send API requests which were allowed by the webserver to unregistered user (as a bot).

file	useragent	Count of 1661783361.1370
cart.do	Mozilla/5.0 (compatible; Googlebot/2.1; +http://www.google.com/bot.html)	175
cart.do	Googlebot/2.1 (http://www.googlebot.com/bot.html)	174
cart.do	Googlebot/2.1 (http://www.googlebot.com/bot.html)	143
product.screen	Googlebot/2.1 (http://www.googlebot.com/bot.html)	126
product.screen	Mozilla/5.0 (compatible; Googlebot/2.1; +http://www.google.com/bot.html)	122
cart.do	Mozilla/5.0 (compatible; YandexBot/3.0; +http://yandex.com/bots)	108
oldlink	Mozilla/5.0 (compatible; Googlebot/2.1; +http://www.google.com/bot.html)	105
product.screen	Googlebot/2.1 (http://www.googlebot.com/bot.html)	102
product.screen	Mozilla/5.0 (compatible; YandexBot/3.0; +http://yandex.com/bots)	92
category.screen	Mozilla/5.0 (compatible; Googlebot/2.1; +http://www.google.com/bot.html)	91
oldlink	Mozilla/5.0 (compatible; YandexBot/3.0; +http://yandex.com/bots)	86
oldlink	Googlebot/2.1 (http://www.googlebot.com/bot.html)	81
category.screen	Googlebot/2.1 (http://www.googlebot.com/bot.html)	79
category.screen	Googlebot/2.1 (http://www.googlebot.com/bot.html)	77
oldlink	Googlebot/2.1 (http://www.googlebot.com/bot.html)	71